

Phishing Alert - Malicious Attachment Detected

Ticket :	SOC14 - Malicious Attachment Detected - Phishing Alert
MITRE ATT&CK :	T1598.001
SMTP Address :	49.234.43.39
Device Action :	Allowed
E-mail Subject :	Invoice
Source Address :	accounting@gmail.carleton.ca
Destination Address :	richard@letsdefend.io

A primeira coisa a se observar é que richard recebeu o email, devido ao device action estar “allowed”

Agora é necessário observar se o usuário clicou nesse anexo

44e65a641fb970031c5fed32467b5018803e0a768608d3e186152102615795

37/62 security vendors flagged this file as malicious

44e65a641fb970031c5fed32467b5018803e0a768608d3e186152102615795

44e65a641fb970031c5fed32467b5018803e0a768608d3e186152102615795.xlsx

ppt exploit executes-dropped file cve-2017-11882

Size: 2.12 MB | Last Analysis Date: 2 days ago

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 30+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Contacted URLs (2)

Scanned	Detections	Status	URL
2025-09-10	10 / 91	401	http://andaluciabeach.net/image/network.exe
2025-09-02	1 / 91	401	http://www.andaluciabeach.net/

O anexo é dado como suspeito e tem duas urls nas quais ele tenta se conectar

Nos logs é possível detectar que um host se conectou a esse domínio

RichardPRD
172.16.17.45

Host Information

Hostname:	RichardPRD	Domain:	letsdefend.local
IP Address:	172.16.17.45	Bit Level:	64-bit
OS:	Windows 10	Primary User:	richard
Client/Server:	Client	Last Login:	2021-01-31 08:28:51

Date	Sender	Recipients	Subject	Final Action
2021-01-31 09:48:30	accounting@gmail.carleton.ca	richard@letsdefend.io	Invoice	Unknown

O host é de Richard, o que bate com quem recebeu o email, pelos logs aparentemente apenas ele recebeu esse email e se conectou com essa URL

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
▼ No Event Time	No Process ID	EXCEL.EXE	—	No Command
▼ No Event Time	No Process ID	notepad.exe	—	No Command
▼ No Event Time	No Process ID	outlook.exe	—	No Command
▼ No Event Time	No Process ID	EQNEDT32.EXE	—	No Command
▼ No Event Time	No Process ID	ccsvchst.exe	—	No Command
▼ No Event Time	No Process ID	JuicyPotato.EXE	—	No Command

Algumas informações estão faltando, vai ser necessário fazer uma análise melhor para detectar o comportamento do malware

Processes 3

Browser Data 0

new

Actions 0

beta

Filter by PID or name

☒ Only important

3392

EXCEL.EXE /dde

1k

1k

80

2168

COM EQNEDT32.EXE -Embedding

804

448

79

1692

ntvdm.exe -i1

305

12

25

Pode-se notar que o EQNEDT32.EXE existe na máquina do usuário e de acordo com a análise é um componente legado conhecido por vulnerabilidades graves exploradas por documentos maliciosos (CVE-2017-11882), que permitia execução remota de código.

Por fim foi confirmado que Richard clicou nesse .xls executando o malware

T1566 – Phishing

T1204 - User Execution

T1203 - Exploitation for Client Execution

Horário:

2021-01-31 09:48:30

IoCs:

Endereços IP:

70.38.21.229

URL:

<http://andaluciabeach.net/image/network.exe>

email sender:

accounting@cmail.carleton.ca

Hashe:

44e65a641fb970031c5efed324676b5018803e0a768608d3e186152102615795

Vetor de Ataque:

Phishing, richard@letsdefend.io recebeu um email com um anexo malicioso e executou esse arquivo

Análise:

Foi verificado que Richard clicou no anexo malicioso, depois de verificar o comportamento do malware, foi possível confirmar seu acesso à URL maliciosa e pela análise da árvore de processos, uma possível exploração do Equation Editor (CVE-2017-11882) para execução de código remoto.

Recomendações:

- Bloquear os IPs e domínios maliciosos
- Treinar funcionários para detectar emails de phishing
- Isolar o Host comprometido da rede
- Adicionar email Filtering, uma medida de proteção para filtrar emails vindos de fontes maliciosas conhecidas e detectar anexos suspeitos